

ROADRESQ

Privacy & Data Governance Document

Data Collection • Location • Vehicles • Documents • Access • Retention • Deletion

Version: 1.0 • **Status:** Production privacy & data governance baseline

MINIMIZE • PROTECT • CONTROL • RETAIN • DELETE • AUDIT

Applies to: Customers • Providers • Admins • Support • Engineering • Vendors • Storage • Analytics

Document Control

Field	Value
Document	RoadResQ Privacy & Data Governance Document
Version	1.0
Status	Production baseline
Owners	Product + Security + Operations + Data Governance
Scope	Personal data, vehicle data, location, provider documents, support evidence, analytics and operational records
Related documents	Security Architecture & Threat Model • SRS • Database/Data Dictionary • API Specification • Provider Operations SOP • Customer Support & Dispute SOP • Backup/DR Plan
Important note	This document is an engineering/operational baseline, not legal advice. Final privacy notices, lawful bases, contracts and retention periods must be validated for the jurisdictions in which RoadResQ operates.

1. Purpose

RoadResQ processes information required to provide roadside assistance, match customers with providers, manage vehicles and bookings, process payments, support disputes, maintain safety and operate the platform. This document defines governance controls so data is collected for clear purposes, accessed only by authorized parties, retained only as long as justified, and securely deleted or anonymized when no longer required.

2. Privacy Principles

- Data minimization: collect only information necessary for a defined product or operational purpose.
- Purpose limitation: do not repurpose sensitive information without an appropriate legal/product basis.
- Transparency: explain important data uses in understandable language.
- Least privilege: give staff and systems only the access required for their role.
- Security by design: protect data throughout collection, transmission, storage and deletion.
- Accuracy: provide mechanisms to correct material customer/provider information.
- Retention limitation: define retention periods or criteria rather than keeping everything indefinitely.
- Accountability: maintain audit records for sensitive access and material data decisions.

3. Data Classification

Class	Examples	Handling
Public	Public provider profile fields intentionally displayed to customers	May be customer-facing; do not include private identifiers.
Internal	Operational metrics, non-sensitive configuration	Authorized workforce/system access.
Confidential	Booking history, service history, contact details, support cases	Role-based access; protected in transit/at rest.
Restricted	Precise location history, identity documents, provider verification evidence, sensitive payment references	Strict least privilege, auditing, limited retention.

4. Data Inventory

Data domain	Examples	Primary purpose
Account	Name, phone/email, authentication state	Account access and communication

Data domain	Examples	Primary purpose
Vehicle	Registration/identifier, make/model, year, service details	Identify vehicle and provide compatible service
Location	Current/manual location, service address, provider location updates	Dispatch, navigation, arrival and service delivery
Booking	Request, status, timestamps, provider assignment	Deliver and audit assistance
Service history	Jobs, inspections, estimates, invoices	Service continuity and customer records
Provider verification	Identity/business/address/service evidence	Trust and provider eligibility
Payments	Transaction/reference/status, invoice/refund records	Payment processing and reconciliation
Communications	Support tickets, messages, notifications	Support and operational communication
Media	Customer/provider photos, videos, voice evidence	Service diagnosis, claims and dispute resolution
Analytics	Product events, performance metrics	Product improvement and reliability
Security/audit	Access events, admin actions, security logs	Security, accountability and incident response

5. Location Data Governance

Location is operationally important to RoadResQ but can be highly sensitive. The platform should collect and expose location only to the extent necessary for dispatch, navigation, safety, support and authorized operational purposes.

- Request customer location when needed for assistance matching and arrival.
- Allow manual location/address entry when GPS is unavailable or denied.
- Do not request continuous location access when a one-time or foreground-only location is sufficient.
- Provider live location should be shared only while operationally necessary for an active job, subject to product policy.
- Avoid retaining high-resolution location history longer than required.
- Customer-facing tracking should expose only the location information necessary for the active service.
- Support/admin access to location history must be restricted and auditable.
- Analytics should use coarse or aggregated location where precise coordinates are not required.

6. Location Lifecycle

Stage	Governance
Collection	Obtain location through approved permission/product flow; provide manual alternative.
Use	Dispatch, ETA, navigation, safety and authorized support.
Sharing	Limit to relevant customer/provider/admin/system actors.
Storage	Encrypt and restrict precise location records.
Retention	Keep precise history only for the defined operational/legal period.
Deletion	Delete or anonymize when the retention purpose expires, subject to lawful holds.
Analytics	Prefer aggregation/coarsening over raw coordinates.

7. Vehicle Information Governance

Vehicle information enables correct assistance and service history but may also be linked to a person.

- Collect only vehicle attributes needed for identification, compatibility, service and history.

- Separate vehicle identity from unnecessary personal information where practical.
- Allow customers to add/remove/update their own vehicles subject to account rules.
- Restrict provider access to vehicle information required for the assigned service.
- Do not expose a customer's complete vehicle history to unrelated providers.
- Use vehicle information in analytics only where it has a defined purpose.
- Retain vehicle records according to account/service/legal retention rules.

8. Provider Verification Documents

Provider onboarding may require identity, business, address or capability evidence. These records require stronger controls than normal profile information.

- Collect only documents required by the configured verification policy.
- Restrict document access to authorized verification/Trust & Safety roles.
- Encrypt documents at rest and in transit.
- Use secure object storage rather than general-purpose application logs.
- Never place document contents in analytics events or normal logs.
- Mask sensitive fields in admin/support views where possible.
- Record document status and verification result separately from the raw document.
- Delete or securely dispose of documents when their retention purpose expires, subject to lawful holds.

9. Customer-Uploaded Evidence

- Photos/videos/voice should be collected only when relevant to service, diagnosis, claims, safety or support.
- Inform users when media may be used for dispute or support investigation.
- Restrict access to the booking/support case scope.
- Generate secure, time-limited access URLs where applicable.
- Prevent public indexing of uploaded evidence.
- Scan/validate uploads and restrict dangerous file types according to security policy.
- Apply defined retention and deletion rules.

10. Payment & Financial Data

- Prefer gateway-hosted/tokenized payment flows.
- Do not store raw card credentials unless explicitly required and permitted.
- Store only the payment references/status information needed for operations and reconciliation.
- Restrict financial records to authorized customer, provider, support and finance contexts.
- Audit refunds, adjustments, payout and privileged financial access.
- Follow the Payment & Settlement Specification for financial record governance.

11. Data Access Model

Actor	Default access scope
Customer	Own account, own vehicles, own bookings, relevant payments, service history and support cases.

Actor	Default access scope
Provider	Own profile/verification status, assigned jobs and only customer/vehicle data needed for assigned work.
Support	Case-scoped customer/provider/booking information needed to resolve the issue.
Provider Operations	Provider profile, verification evidence and operational performance within role scope.
Finance	Financial records needed for payment, refund, payout and reconciliation operations.
Trust & Safety	Restricted incident, verification and evidence data required for investigation.
Admin	Operational oversight; sensitive data only where explicitly authorized.
Engineering	Minimum production access required for technical troubleshooting; avoid routine access to raw personal data.

12. Object-Level Authorization

- Every API request accessing customer/provider data must be authorized against the specific object.
- Role alone is not sufficient: a provider role must not automatically access every customer.
- Booking-scoped data should be accessible only to relevant parties and authorized operations staff.
- Support access should be case-scoped where possible.
- Admin interfaces must enforce the same server-side authorization rules as APIs.
- Never rely only on hidden UI controls for privacy protection.

13. Administrative Access

- Use separate privileged roles for verification, finance, support, Trust & Safety and system administration where practical.
- Require strong authentication for privileged accounts.
- Use least privilege and periodic access review.
- Log access to restricted data.
- Avoid exporting raw sensitive data unless required.
- Use time-limited elevated access for exceptional troubleshooting where supported.
- Immediately revoke access when a staff role no longer requires it.

14. Third-Party Data Sharing

Third party	Potential data shared	Governance
Maps/location provider	Coordinates/address required for mapping	Minimize precision and fields; follow vendor contract/policy.
Payment provider	Payment/order details required for transaction	Use approved integration and security controls.
SMS/OTP provider	Phone/contact and OTP metadata	Share only required authentication data.
Push/email provider	Notification destination and message content	Avoid sensitive content where unnecessary.
Cloud/object storage	Application data/media/documents	Encryption, access controls and retention.
Analytics provider	Product events/metrics	Minimize personal data; use pseudonymous IDs where practical.

15. Data Processing Register

RoadResQ should maintain a living register for each major data-processing activity.

Field	Required record
Processing activity	Name of the business/process.
Purpose	Specific reason data is processed.
Data categories	Exact data fields/categories involved.
Data subjects	Customer/provider/admin/other relevant users.
Systems	Database, storage, vendor or service involved.
Access roles	Who can access the data.
Retention	Period or documented retention criteria.
Sharing	Third parties/recipients.
Security	Controls applied.
Deletion	Deletion/anonymization procedure.

16. Retention Principles

- Retention must be tied to a business, security, accounting, dispute or legal purpose.
- Different data categories should have different retention periods.
- Do not use one indefinite retention period for all platform data.
- When a record reaches the end of its retention period, delete or anonymize it unless a documented exception applies.
- Legal holds, active disputes, fraud investigations and financial/accounting obligations may temporarily extend retention.
- Retention schedules must be reviewed when product or legal requirements change.

17. Recommended Retention Framework

The periods below are engineering starting points, not legal requirements. Final periods must be approved based on applicable law, contracts, accounting needs and RoadResQ policy.

Data type	Recommended baseline approach
Active account data	Retain while account is active and for a defined post-closure period.
Vehicle profile	Retain while needed for account/service continuity; delete/anonymize after defined closure period.
Precise live location	Prefer shortest practical operational retention; avoid indefinite history.
Booking records	Retain for service history, support, accounting and dispute requirements.
Payment/financial records	Retain according to accounting, payment and legal obligations.
Provider verification documents	Retain only for verification/compliance/claims needs; restrict and securely delete when no longer required.
Support/dispute evidence	Retain through resolution plus defined dispute/claims period.
Security/audit logs	Retain according to security monitoring and incident requirements.
Analytics	Prefer aggregated/anonymized retention for long-term analysis.

18. Deletion & Erasure

- Provide a controlled process for account/data deletion requests where applicable.
- Verify requester identity before executing deletion.
- Identify linked data across operational systems and storage.
- Delete direct personal data where no exception applies.

- Anonymize records that must remain for legitimate operational/accounting reasons where possible.
- Delete associated media/documents when their retention purpose has expired.
- Revoke active sessions/tokens as part of account closure where appropriate.
- Record deletion request and outcome without retaining unnecessary deleted content.
- Do not claim complete deletion if legally/operationally required records must remain.

19. Deletion Exceptions

Exception	Handling
Active dispute	Retain relevant evidence until resolution/required post-resolution period.
Fraud/security investigation	Preserve evidence under authorized investigation retention.
Financial/accounting requirement	Retain required financial records; restrict access.
Legal hold	Suspend deletion for identified records.
Backup copy	Allow controlled backup expiry rather than restoring deleted data into active systems.
Aggregated/anonymized analytics	May remain when individuals are no longer reasonably identifiable and policy permits.

20. Backup & Deletion Interaction

- Deletion from production does not require unsafe manipulation of immutable backups.
- Document backup expiry/rotation periods.
- Ensure deleted records are not routinely restored into active systems.
- If a restore is required, reapply applicable deletion/retention controls.
- Restrict backup access and encrypt backups.
- Follow the Backup & Disaster Recovery Plan for recovery procedures.

21. Data Accuracy & Correction

- Customers should be able to correct ordinary profile and vehicle information.
- Providers should be able to request correction of provider/business information.
- Support must have a controlled correction process for operational errors.
- Material changes to verified provider information may trigger re-verification.
- Financial history and audit records should not be silently overwritten; corrections should be versioned or represented by adjustments.

22. Consent & Permission UX

- Explain why location or other device permissions are requested.
- Request permissions at the point they are needed where practical.
- Provide a usable alternative when a non-essential permission is denied.
- Do not misrepresent optional permissions as mandatory.
- Record permission state only to the extent required for product operation.
- Product privacy notices and consent mechanisms must be reviewed by the appropriate legal/privacy authority.

23. Analytics & Tracking Governance

- Define a purpose for each analytics event.
- Avoid sending raw identity documents, precise location or sensitive support content to analytics.

- Use pseudonymous identifiers where possible.
- Do not include passwords, OTPs, payment secrets or access tokens in events.
- Define event retention and deletion policies.
- Restrict analytics access to authorized teams.

24. Logging Rules

- Logs must not contain passwords, OTPs, API secrets or raw payment credentials.
- Avoid full identity-document content in logs.
- Minimize precise location in logs; prefer event-level location metadata or coarse values when sufficient.
- Use request/correlation IDs to debug without copying personal content.
- Apply role-based access to production logs.
- Define log retention independently from application-data retention.

25. Data Export & Portability

- Where applicable, provide a controlled export of user-accessible data.
- Verify requester identity before export.
- Export only data the requester is entitled to receive.
- Avoid exposing another person's information in shared records.
- Use secure, time-limited delivery.
- Audit export requests and outcomes.

26. Data Breach / Privacy Incident

- Detect and classify suspected unauthorized access, disclosure, loss or destruction.
- Contain affected systems/accounts where necessary.
- Preserve relevant security evidence.
- Identify affected data categories and users.
- Escalate to the designated security/privacy authority.
- Assess notification obligations under applicable law and contracts.
- Document incident timeline, decisions and corrective actions.
- Review controls after closure.

27. Vendor Governance

- Maintain an inventory of third parties processing RoadResQ data.
- Document the data shared and purpose for each vendor.
- Review security/privacy posture before production use.
- Use appropriate contractual/data-processing terms where required.
- Review vendor access and data retention.
- Remove unused integrations and revoke credentials.

28. Data Residency & Cross-Border Processing

If RoadResQ operates across jurisdictions, data storage and transfer locations must be documented. Cross-border processing should use the legally appropriate mechanism and contractual controls for the applicable jurisdictions. Infrastructure regions should be chosen deliberately rather than assumed to satisfy all regulatory requirements.

29. Privacy by Design — Product Requirements

- Collect location only when the active feature needs it.
- Show provider/customer information only to the relevant party.
- Use masked contact/calling mechanisms where direct numbers are not required.
- Provide text alternatives instead of exposing unnecessary raw data.
- Separate public provider profile fields from restricted verification evidence.
- Use secure temporary access for sensitive media/documents.
- Make privacy-sensitive actions auditable.
- Build deletion/retention behavior into data models rather than treating it as a manual afterthought.

30. API & Database Governance

- Every sensitive endpoint requires authentication and object-level authorization.
- Use explicit field allowlists for API responses.
- Avoid returning sensitive fields by default.
- Use database constraints and service-layer authorization together.
- Encrypt backups and sensitive storage.
- Use database roles with minimum privileges.
- Maintain migration history and avoid destructive schema changes without a data-retention review.

31. Access Review

Review	Minimum requirement
Staff access review	Periodic review of privileged/support/finance/Trust & Safety access.
Provider access	Confirm provider can only access assigned/relevant customer data.
Admin role review	Remove unused elevated permissions.
Vendor access	Review service accounts and integration scopes.
Production access	Review exceptional engineering access and revoke when no longer needed.
Audit review	Investigate unusual restricted-data access patterns.

32. Data Governance Roles

Role	Responsibility
Product	Define legitimate product data requirements and minimize unnecessary collection.
Security	Protect systems, access, logs, secrets and incident response.
Privacy/Data Governance	Maintain data inventory, retention, deletion and privacy controls.
Operations	Use customer/provider data only for authorized operational purposes.
Finance	Govern financial records and reconciliation retention.
Engineering	Implement authorization, storage, deletion and audit mechanisms.
Support	Handle customer data only within case scope.

Role	Responsibility
Vendors	Process only contracted/authorized data for defined purposes.

33. Data Subject Request Workflow

- 1. Receive request through approved channel.
- 2. Verify requester identity.
- 3. Determine request type: access, correction, deletion, export or other applicable request.
- 4. Identify systems/data within scope.
- 5. Check legal/operational exceptions.
- 6. Execute approved access/correction/deletion/export workflow.
- 7. Record completion and any exception.
- 8. Escalate complex privacy/legal questions to the designated authority.

34. Privacy-Sensitive Event Catalog

Event	Governance rule
Location collected	Do not include raw coordinates in general analytics/logs unless necessary.
Document viewed	Audit restricted access.
Document uploaded	Store securely; validate file; apply retention.
Data exported	Audit requester and delivery.
Deletion requested	Create controlled deletion workflow.
Deletion completed	Record outcome without retaining deleted content unnecessarily.
Privileged access	Record actor, object, purpose where appropriate.
Privacy incident	Create security/privacy case and preserve evidence.

35. Privacy Risk Register

Risk	Control
Excessive location retention	Short operational retention + aggregation.
Unauthorized provider access to customer data	Object-level authorization + booking scope.
Document exposure	Restricted object storage + role-based access.
Sensitive data in logs	Logging allowlists/redaction.
Duplicate personal records	Controlled identity/account model.
Stale access permissions	Periodic access reviews.
Improper deletion	Retention schedules + deletion workflow + audit.
Backup reintroduces deleted data	Backup lifecycle + post-restore deletion controls.
Vendor over-collection	Data minimization + vendor governance.

36. Privacy Testing & QA

- Attempt to access another customer's booking through manipulated object IDs.
- Attempt to access provider verification documents with non-authorized roles.

- Verify provider sees only data required for an assigned job.
- Verify support cannot access unrelated sensitive records.
- Verify deleted/closed accounts cannot authenticate normally.
- Verify expired access tokens cannot retrieve sensitive data.
- Verify sensitive fields are absent from logs and analytics.
- Verify location is not retained beyond configured operational limits.
- Verify deletion requests respect active dispute/legal-hold exceptions.
- Verify backup restore procedures do not casually re-expose deleted personal data.

37. Privacy Monitoring

- Monitor unusual access to restricted documents.
- Monitor repeated authorization failures.
- Monitor bulk data export/download behavior.
- Monitor unexpected location-data access.
- Monitor sensitive data appearing in logs.
- Monitor data-retention jobs and deletion failures.
- Alert on disabled/failed security controls.
- Review vendor integration changes affecting data flow.

38. Operational Checklists

New Data Feature Checklist

- ■ Purpose documented
- ■ Minimum required fields identified
- ■ Data classification assigned
- ■ Access roles defined
- ■ Retention/deletion rule defined
- ■ Third-party sharing assessed
- ■ Security controls implemented
- ■ Privacy notice/UX impact reviewed
- ■ QA/privacy tests added

Deletion Checklist

- ■ Requester verified
- ■ Scope identified
- ■ Legal/operational holds checked
- ■ Production data deleted/anonymized as applicable
- ■ Media/documents handled
- ■ Sessions/tokens revoked where applicable
- ■ Backup lifecycle considered
- ■ Outcome recorded

39. Production Privacy Acceptance Criteria

ID	Acceptance criterion
PRIV-01	All major data categories have documented purpose and classification.
PRIV-02	Sensitive location access is role/object controlled.
PRIV-03	Provider verification documents are restricted and audited.
PRIV-04	Precise location is not retained indefinitely.
PRIV-05	Customer vehicle/service history is protected from unrelated users/providers.
PRIV-06	Deletion/retention workflows exist and are tested.
PRIV-07	Legal/dispute/financial retention exceptions are documented.
PRIV-08	Sensitive data is excluded or redacted from ordinary logs/analytics.
PRIV-09	Privileged access is periodically reviewed.
PRIV-10	Third-party data sharing is inventoried and minimized.
PRIV-11	Privacy/security incidents have an escalation workflow.
PRIV-12	Data governance ownership is assigned before production launch.

40. Definition of Done

- Data inventory is maintained for customer, provider, vehicle, location, payment, media and operational data.
- Each data category has a defined purpose and classification.
- Access is enforced server-side with RBAC and object-level authorization.
- Location collection, sharing and retention are explicitly controlled.
- Provider verification documents use restricted storage and access.
- Retention periods/criteria are configured or documented for major datasets.
- Deletion/anonymization workflows are implemented.
- Legal/dispute/financial hold exceptions are supported.
- Logs and analytics do not expose unnecessary sensitive data.
- Third-party data flows are documented.
- Privacy/security incident escalation is defined.
- Access reviews and privacy QA are part of production operations.
- Final privacy notices, contractual terms and jurisdiction-specific obligations are reviewed by the appropriate legal/privacy authority.

41. Final Data Governance Standard

RoadResQ should treat data as a controlled operational asset, not an unlimited resource. Location, vehicle information, verification documents, service history, payment records and support evidence each require different levels of protection and retention. The production standard is simple: **collect what is needed, use it for a defined purpose, expose only what is necessary, protect it throughout its lifecycle, retain it for a justified period, and securely delete or anonymize it when that purpose ends.**